

Risk Matrix — Mobile Trading App Launch

Likelihood and Impact rated Low / Medium / High. Severity = the combination, used to order mitigation priority (Critical > High > Medium > Low).

#	Risk	Likelihood	Impact	Severity	Mitigation
1	Duplicate order from double-tap or retried network request	Medium	Critical	Critical	Idempotency keys on order submission; disable the submit control immediately on tap; API-level test asserting a retried request never creates a second order
2	Balance/ledger drift after a burst of activity or backgrounded app	Medium	Critical	Critical	Reconciliation test: deposit → multiple trades → withdraw, assert displayed balance matches backend ledger at every step; re-fetch balance (not just trust cached state) on app foreground
3	Ambiguous order state on connection loss (user unsure if it succeeded)	High	High	Critical	Explicit pending/failed/succeeded UI state persisted locally until confirmed by server; E2E test simulating a dropped connection mid-submit
4	No existing regression suite — late fixes ship untested	High	High	Critical	Stand up API + smoke E2E coverage in week one on the money-touching paths specifically, so late fixes have *some* safety net before release
5	App Store rejection on submission (financial-app disclosure/licensing)	Medium	Critical	Critical	Review App Store/Play Store financial-app guidelines in week one, not at submission; internal compliance checklist signed off before RC cut
6	No kill switch — a critical bug post-launch requires emergency resubmission	Medium	Critical	High	Remote feature flag to disable trading/specific order types without an app-store release
7	Session expires mid-trade without clear messaging	Medium	High	High	Explicit session-expiry UX (not a silent failure); test placing an order with an expired/about-to-expire token
8	Rounding/precision error on specific decimal values or asset pairs	Medium	High	High	Data-driven tests across multiple assets/amounts including boundary values (min trade size, max precision), not one hardcoded happy path
9	Crash or broken flow on an untested device/OS combination	Medium	High	High	Cloud device farm run across top real-world iOS/Android combinations before

#	Risk	Likelihood	Impact	Severity	Mitigation
					RC sign-off; crash reporting live from day one
10	Biometric login fails with no usable fallback on some devices	Low	High	Medium	Explicit fallback-path test (PIN/password) on top of the biometric happy path
11	Sensitive data (tokens/balances) logged or cached in plaintext	Low	Critical	Medium	Security review of logging and local storage before release; automated check in CI grepping for common sensitive-field leakage patterns
12	Push notification for order fill/price alert not delivered or deep-links incorrectly	Medium	Medium	Medium	Manual + automated check of notification delivery and deep-link target as part of smoke suite
13	Marketing/content region regressions (banners, nav) go unnoticed	Low	Low	Low	Covered by the automated content/navigation regression suite already in this repo's pattern
14	Broken outbound link (App Store, support, legal)	Low	Medium	Low	Automated broken-link check across all nav/content links, run in CI
15	Localization/timezone inconsistency in trade timestamps	Low	Medium	Low	Explicit timezone test if launch market spans multiple zones; otherwise flagged as fast-follow, not launch-blocking

How this is used

- **Critical/High** items are release blockers — no go-live until mitigated or explicitly, individually waived by QA + engineering + product leads with a written reason (see `release-readiness-checklist.md`).
- **Medium** items are strongly preferred to fix pre-launch but can be waived with sign-off if timeline forces a trade-off.
- **Low** items are tracked but don't block the release candidate.